Avera

Avera Health Technology Proposal Form – Vendor Discovery

Policy: Technology Project Management (REG38)

SECTION 2: VENDOR DISCOVERY

Ask the vendor to have a member of their technical team complete this section. ONLY send this section to the vendor. Avera's Information Technology Security team will contact the vendor for any follow-up inquiries.

2.1 SUPPORTING DOCUMENTATION	
Please provide the following:	
☐ HIPAA and HITECH compliance	
☐ Third-party security assurances *(i.e. ISO, SOC 2 Type 2, HITRUST, other)* *Required for Cloud and Vendor Hosted products where Confidential Data (PHI, PII, Financial) is transmitted or stored. If not available, please notify us so we can discuss options and timelines.*	
☐ Product / Installation / Integration Guides	
☐ Cyber-liability insurance certificate *(i.e. COI)*	Amount: $
☐ Vulnerability / penetration assessment	
☐ MDS2 or CBOM *(i.e. The products Manufacture Disclosure Statement or Cyber Bill of Materials for equipment and devices as applicable.)*	
☐ Data Flow Diagram	
☐ Network Diagram	
☐ Sample Data Access Audit Report *(see minimum content listed below)*	
☐ Policy regarding BCP/DR (*Evidence you can share based on your corporate policies*.)	

2.2 VENDOR CONTACT INFORMATION	
(LEGAL) Name (and dba):	
Parent Company Legal Name:	
Product Name:	
Website Domain(s):	
Main Contact NAME & TITLE:	
Main Contact EMAIL & PHONE:	
IT Security Contact NAME & TITLE:	
IT Security Contact EMAIL & PHONE:	
Privacy Officer NAME:	
Privacy Officer EMAIL & PHONE:	

2.3 VENDOR QUESTIONS		
Questions	**Response**	**Notes**
What is this product and how does it work?		
Where is this application hosted?	☐ Avera Data Centers ☐ Vendor Hosted ☐ Hybrid ☐ Third-Party Host	
For products on the Avera network and/or hosted by Avera Health, our security products **must** be able to be used. If this is not possible, please inform us so we can discuss.		
Does this product have any cloud hosted functionality?	☐ Yes ☐ No Type: (IaaS, SaaS, Back-up Storage, etc.): AWS, MS Azure, GCP, other:	
Is any data used, transmitted, or stored outside the United States or US territories? (offshore)	☐ Yes ☐ No If Yes, where and what data?	
Is data stored in the software or device?	☐ Software ☐ Device ☐ Other: ☐ No Data is Stored	
Software/OS required for installation.	List: Managed by: ☐ Avera ☐ Vendor	

Avera

Avera Health Technology Proposal Form – Vendor Discovery

Policy: Technology Project Management (REG38)

Hardware required for installation.	List: Provided by: ☐ Avera ☐ Vendor Managed by: ☐ Avera ☐ Vendor
User Interface Type?	☐ N/A ☐ Web Application/Portal ☐ Locally Installed App ☐ Mobile App ☐Vendor Device/Instrument ☐ Other:
If no user or admin accounts skip to end of this section.	
Note: If confidential data (PHI, PII, or Financial) leaves Avera's network, accounts must have SSO or MFA. If not possible, please let us know so we can discuss alternatives and/or timelines.	
Does the application support SSO? (SAML, ADFS, LDAP, Azure, etc.)	☐ Yes ☐ No Type:
Is MFA available?	☐ Yes ☐ No Type:
Is there an account management interface or API?	☐ Yes ☐ No: If no, does the app accept periodic flat files for account creation and/or access changes?
Does the application have a session timeout?	Time interval: Configurable ☐ Yes ☐ No
Are accounts automatically disabled if users do not login for a specified amount of time?	☐ Yes ☐ No Default time period: Configurable: ☐ Yes ☐ No
Describe intended data transmission outbound from Avera.	Type: Protocol: Port: Destination:
Describe intended data transmission inbound to Avera.	Type: Protocol: Port: Destination:
Required white listed URLs/IPs	
Is data encrypted?	☐ In Transit ☐ In Storage ☐ No ☐ N/A
Is remote access into Avera's network required for Vendor support?	☐ Yes ☐ No Type: ☐ SecureLink ☐ VPN ☐ Other: _____ ***SecureLink is required to be used for all Vendor Support access for products on our network.***
Identify Data Fields created, processed, transmitted, or stored:	Confidential Data (PHI/PII) ☐ Name ☐ Address ☐ Phone/Fax Numbers ☐ Email address ☐Dates related to an individual ☐ DOB ☐ Admission, discharge, treatment dates ☐ Date of Death ☐ Social Security Number (SSN) ☐ Medical Record Number ☐ Health Plan Beneficiary number ☐ Account Number ☐ Certificate or License Number ☐ Employee ID Number ☐ Photo or Video Recording ☐ Images (Diagnostic) ☐ Fingerprint, voice print, retinal scan ☐ Web URL ☐ Internet Protocol (IP) Address ☐Credit Card Number ☐ Vehicle Identifiers ☐Other identifiers: _____

Avera

Avera Health Technology Proposal Form – Vendor Discovery

Policy: Technology Project Management (REG38)

If no PHI, PII, or Financial data is created, processed, transmitted, or stored skip the highlighted (next 4) questions.		
How long is PHI, PII, or Financial data stored?		
Are access audit reports available? (Please provide a sample report. At minimum, the report should contain patient name, user ID/name, date and time of access, and information viewed.)	☐ Yes ☐ No ☐ N/A	For How Long?
Will Avera be able to run the reports directly from the product?	☐ Yes ☐ No If No, explain how reports are run below.	
Does the Vendor have that ability to delete or return PHI and PII at the end of the contract?	☐ Yes ☐ No ☐ N/A If No, explain why data cannot be deleted below.	
Summarize data breaches Vendor or Subcontractor has experienced in last five (5) years.		
Describe outsourced or subcontracted services for this product including security functions.		